

CRAFT Configuration and Validation

Certificate Request Agent for Tickets | Administrator Reference

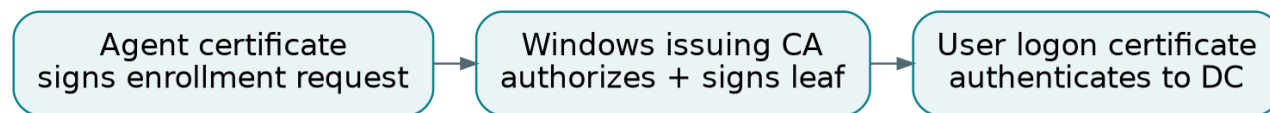


Figure 1. CRAFT uses an agent certificate for enrollment and a user certificate for PKINIT.

Dedicated User-Certificate Template

Use this profile to prepare a lab deployment, then inspect an issued certificate. The CA controls issuance; CSR extensions are requests. CRAFT requires all three client EKUs listed below. [1, 2]

Property	Requested / Required by This Implementation
Subject and identity	Requested CN is configurable. UPN otherName 1.3.6.1.4.1.311.20.2.3 must match the directory-resolved UPN.
Client EKUs	Client Authentication: 1.3.6.1.5.5.7.3.2 Smart Card Logon: 1.3.6.1.4.1.311.20.2.2 PKINIT Client Authentication: 1.3.6.1.5.2.3.4
Key and basic constraints	RSA-3072; explicit CA:FALSE, no path length. digitalSignature required; keyCertSign/cRLSign forbidden. CSR also requests keyEncipherment.
SID and template	CA-issued SID extension 1.3.6.1.4.1.311.25.2 must match the resolved AD objectSid. Template OID must match configuration.
Validity and trust	Default cap: ten hours TOTAL, including backdating. Require matching key, valid chain and current CRLs; no UPN-only mapping.
Agent / DC profiles	Agent: Certificate Request Agent ECU 1.3.6.1.4.1.311.20.2.1. DC: a valid PKINIT KDC certificate and configured KDC trust/hostname checks.

Editable Settings

```

certificate_cn={user}
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
cert_remaining_max_seconds=36000
cert_total_max_seconds=36000
  
```

CN tokens are {user}, the directory-resolved {upn}, and {domain}; for example, Linux {user}. The result must be 1-64 printable ASCII characters. The CA may replace it. Preserve AD-built subject/SAN and identity restrictions.

Both CES modes require service_principal and submitter.keytab for LDAP/GSSAPI. Pin the GC host and search base with gc_url and gc_base_dn. Manage local/AD account names centrally; no static users file is used.

Build and Validate in a Lab

Preparation	Required Action
Linux build	C++20 with std::format; OpenSSL 3, MIT Kerberos, curl, libxml2, OpenLDAP and Cyrus SASL libraries. Install MIT PKINIT and SASL GSSAPI runtime modules. See source/README.md.
Windows enrollment	Restrict the signing agent to the template and approved users. CES must allow initial enrollment via Negotiate or mTLS. Both modes need the directory keytab; mTLS also needs a TLS-client certificate. [3]
DC policy and AES	Policy must permit a 10-hour initial TGT and 7-day renewal window; PKINIT can limit the initial grant by certificate expiry. Require AES256/AES128 for user and transport tickets. [1, 4, 7]
Installation boundary	Only craft becomes setuid. The craft account/group holds credentials; callers use craft-users. Review the Windows helper, complete CA restrictions and keep configuration disabled until ready.

```
cmake -S source -B build -DCMAKE_BUILD_TYPE=Release
cmake --build build -j2
ctest --test-dir build --output-on-failure
```

Acceptance Checks

1. Verify directory lookup and CA audit identity. Inspect issued UPN, recipient SID, template, key, three EKUs, CN behavior, chain, CRLs and total validity.
2. Invoke craft directly as an approved user. Inspect TGT start/end time, renewable/nonforwardable/nonproxiable flags, and AES session and ticket encryption with `klist -ef`.

```
if cache=$(/usr/local/bin/craft); then
    export KRB5CCNAME="$cache"
    klist -ef -c "$KRB5CCNAME"
fi
```

3. Confirm strict refusal of shortened grants preserves an existing cache. Test unauthorized users, changed names, wrong identities/keys/templates, RC4, expired CRLs, unsafe homes, concurrency and transport failure.
4. Test a real Kerberos application. Review AUTHPRIV/CA/CES/KDC logs and document credential rotation, CRL refresh, account lifecycle, cache protection and incident response.

Offline fixtures are synthetic. They do not establish live LDAP/CES/PKINIT interoperability or validate the installed setuid boundary. Run and record the current tests; complete source/TESTING.md in the lab.

Primary References

- [1] [RFC 4556, sections 3.2.2–3.2.3: client certificate usage and ticket/key lifetime](#)
- [2] [Microsoft MS-WCCE: CA certificate SID security extension](#)
- [3] [Microsoft: Configure Certificate Enrollment Web Service](#)
- [4] [MIT Kerberos: encryption types, ticket lifetime and KDC options](#)
- [5] [MIT Kerberos: PKINIT configuration and Active Directory considerations](#)
- [6] [Microsoft KB5014754: strong certificate-to-account mapping](#)
- [7] [Microsoft: Maximum lifetime for user ticket \(hours\)](#)

Source implementation and test suite: see source/ in the repository.

License

CRAFT source code, scripts, configuration examples, and documentation are licensed under the GNU General Public License, version 3 (SPDX: GPL-3.0-only). See the repository LICENSE file or <https://www.gnu.org/licenses/gpl-3.0.html> for the full terms. This material is provided without warranty, as described in the license.